

PLAN DE RECUPERACIÓN Y RESPUESTA ANTE INCIDENTES

Proyecto Final de Ciberseguridad - 4Geeks
João Paulo Medeiros

1. Introducción

El presente documento define un plan de recuperación y respuesta ante incidentes de seguridad para el entorno analizado durante el proyecto final de ciberseguridad. Incluye además un Sistema de Gestión de Seguridad de la Información (SGSI) básico elaborado conforme a los principios de la norma ISO 27001.

El objetivo principal es establecer procedimientos organizados para:

- Detectar incidentes de seguridad
- Contener amenazas
- Recuperar servicios afectados
- Minimizar impactos operacionales
- Garantizar la continuidad de servicios críticos
- Reducir riesgos futuros

El plan fue elaborado considerando las vulnerabilidades identificadas en el servidor Debian Linux durante el análisis de seguridad.

2. Objetivos del Plan

- Proteger la disponibilidad de los servicios
- Minimizar interrupciones operacionales
- Reducir impacto financiero y técnico
- Garantizar recuperación rápida del sistema
- Mantener integridad de la información
- Establecer medidas preventivas futuras

3. Alcance

Elemento	Descripción
Servidor	Debian Linux
Servicios críticos	SSH, FTP, Apache, WordPress, MariaDB
Ambiente	Red local de laboratorio
Tipo de incidentes	Accesos no autorizados, fallos de configuración, compromiso de servicios

4. Clasificación de Incidentes

4.1 Incidente Crítico

Incidentes que permiten:

- Acceso administrativo
- Control total del servidor
- Robo de información
- Eliminación de archivos
- Interrupción completa de servicios

Ejemplo: Login remoto SSH utilizando root

4.2 Incidente Alto

Incidentes que permiten:

- Acceso parcial al sistema
- Exposición de servicios
- Enumeración de información sensible

Ejemplo: Acceso FTP anónimo

4.3 Incidente Medio

Incidentes que afectan:

- Disponibilidad parcial
- Configuración incorrecta
- Funcionamiento de aplicaciones

Ejemplo: WordPress configurado con localhost

5. Procedimiento de Respuesta a Incidentes

5.1 Identificación

La primera etapa consiste en detectar actividades sospechosas o configuraciones inseguras.

Actividades realizadas

- Escaneo de puertos con Nmap
- Verificación de servicios expuestos
- Revisión de configuraciones
- Análisis de logs del sistema
- Validación de autenticaciones

Herramientas utilizadas

Herramienta	Función
Nmap	Reconocimiento y enumeración
Journalctl	Revisión de logs
Gobuster	Enumeración web
FTP / SSH	Validación de accesos
MariaDB	Revisión de configuraciones

5.2 Contención

Después de identificar las vulnerabilidades, se aplicaron medidas inmediatas para reducir el riesgo.

Acciones realizadas

FTP

- Deshabilitación de acceso anónimo

SSH

- Bloqueo de login remoto como root

WordPress

- Corrección de configuración siteurl y home

5.3 Erradicación

La etapa de erradicación tuvo como objetivo eliminar las configuraciones inseguras identificadas.

Vulnerabilidad	Acción Correctiva
FTP anonymous	anonymous_enable=NO
SSH root login	PermitRootLogin no
WordPress localhost	Corrección de parámetros siteurl/home

5.4 Recuperación

Después de aplicar las correcciones, los servicios fueron validados nuevamente.

Validaciones realizadas

- Verificación de acceso FTP
- Verificación de autenticación SSH
- Verificación del panel WordPress
- Confirmación de funcionamiento Apache
- Validación de conectividad

Resultado

Todos los servicios continuaron operativos después de las correcciones aplicadas.

5.5 Lecciones Aprendidas

- Configuraciones por defecto pueden representar riesgos graves
- Servicios innecesariamente expuestos aumentan la superficie de ataque
- El acceso root remoto representa un riesgo crítico
- Las aplicaciones web deben revisarse correctamente después de la instalación
- La revisión periódica de configuraciones es esencial

6. Plan de Continuidad Operacional

En caso de incidente grave, se establecen las siguientes prioridades:

Prioridad	Servicio
Alta	SSH
Alta	Apache
Alta	MariaDB
Media	WordPress
Baja	FTP

7. Procedimientos de Recuperación

7.1 Recuperación del Servidor

En caso de compromiso:

1. Aislar el servidor de la red
2. Revisar logs del sistema
3. Identificar accesos sospechosos
4. Cambiar credenciales
5. Restaurar configuraciones seguras
6. Aplicar actualizaciones
7. Validar integridad del sistema

7.2 Recuperación de WordPress

En caso de fallo de la aplicación:

8. Verificar Apache
9. Verificar MariaDB
10. Revisar parámetros siteurl/home
11. Revisar permisos web
12. Validar acceso remoto

7.3 Recuperación SSH

En caso de intento de acceso no autorizado:

13. Revisar logs SSH
14. Bloquear IPs sospechosas
15. Cambiar credenciales
16. Deshabilitar root login
17. Implementar autenticación por clave pública

8. Medidas Preventivas Futuras

- Restricción de servicios innecesarios
- Monitoreo continuo
- Auditorías periódicas
- Gestión segura de contraseñas
- Uso de MFA cuando sea posible
- Copias de seguridad periódicas
- Revisión constante de logs
- Actualizaciones de seguridad automáticas

9. Sistema de Gestión de Seguridad de la Información (SGSI)

Esta sección establece un SGSI básico conforme a los principios de la norma ISO 27001, aplicado al entorno analizado en el proyecto.

9.1 Contexto de la Organización

El entorno evaluado corresponde a un servidor Debian Linux desplegado en una red local de laboratorio, con servicios expuestos accesibles desde una máquina Kali Linux dentro de la misma red.

Elemento	Descripción
Sistema operativo	Debian Linux
Dirección IP del servidor	192.168.1.48
Red	192.168.1.0/24
Servicios críticos expuestos	FTP (21), SSH (22), HTTP/Apache (80), WordPress, MariaDB (3306)
Entorno	Red local de laboratorio

9.2 Activos de Información

Activo	Tipo	Criticidad
Servidor Debian Linux	Hardware/Sistema operativo	Alta
Servicio SSH	Servicio de acceso remoto	Alta
Servicio Apache/WordPress	Aplicación web	Alta
Base de datos MariaDB	Datos/Información	Alta
Servicio FTP	Servicio de transferencia	Media
Archivos de configuración del sistema	Información de configuración	Alta
Logs del sistema	Registros de auditoría	Media

9.3 Análisis y Evaluación de Riesgos

La evaluación de riesgos considera dos variables: probabilidad de ocurrencia e impacto potencial sobre la confidencialidad, integridad y disponibilidad de la información.

Matriz de Riesgo (Probabilidad × Impacto)

Probabilidad / Impacto	Bajo	Medio	Alto
Alta	Medio	Alto	Crítico
Media	Bajo	Medio	Alto
Baja	Bajo	Bajo	Medio

ID	Descripción del Riesgo	Activo Afectado	Probabilidad	Impacto	Nivel	Estado
R-01	Acceso FTP mediante autenticación anónima	Servicio FTP	Alta	Medio	Alto	Mitigado
R-02	Acceso SSH remoto con usuario root	Servidor / SSH	Alta	Alto	Crítico	Mitigado
R-03	WordPress con URL incorrecta (localhost)	WordPress	Alta	Medio	Alto	Mitigado
R-04	Servicios innecesarios expuestos en la red	Servidor	Media	Medio	Medio	Pendiente
R-05	Ausencia de monitoreo continuo de logs	Logs del sistema	Media	Alto	Alto	Pendiente
R-06	Uso de contraseñas débiles en el sistema	Cuentas de usuario	Alta	Alto	Crítico	Pendiente

9.4 Políticas de Seguridad

Control de Acceso

- El acceso remoto vía SSH debe realizarse con usuarios de privilegios limitados. El login directo con root está prohibido.
- La autenticación anónima en cualquier servicio está prohibida.
- Las credenciales deben tener mínimo 12 caracteres combinando mayúsculas, minúsculas, números y caracteres especiales.
- Se debe implementar autenticación SSH mediante clave pública.

Gestión de Servicios

- Todos los servicios expuestos deben tener justificación operacional documentada.
- Los servicios no necesarios deben ser deshabilitados o restringidos.
- Las configuraciones deben revisarse periódicamente para detectar configuraciones inseguras por defecto.

Monitoreo y Auditoría

- Los logs de autenticación deben revisarse periódicamente para identificar accesos sospechosos.
- Cualquier intento de acceso fallido repetido debe ser investigado.
- Se deben mantener registros de modificaciones en archivos de configuración críticos.

9.5 Controles ISO 27001 Aplicados

Control ISO 27001	Acción Aplicada	Estado
A.8.2 — Gestión de accesos privilegiados	Deshabilitación del login SSH como root (PermitRootLogin no)	Implementado
A.8.3 — Gestión de accesos de información	Deshabilitación del acceso FTP anónimo (anonymous_enable=NO)	Implementado
A.8.9 — Gestión de la configuración	Corrección de parámetros siteurl/home en WordPress y revisión de sshd_config y vsftpd.conf	Implementado
A.8.16 — Actividades de monitoreo	Análisis de logs SSH mediante journalctl	Implementado parcialmente
A.8.6 — Gestión de servicios expuestos	Identificación de servicios innecesarios mediante Nmap	Implementado

Control ISO 27001	Acción Aplicada	Estado
A.8.24 — Uso de criptografía	Recomendación de autenticación SSH mediante clave pública	Pendiente

9.6 Plan de Mejora Continua

Conforme al ciclo PDCA (Plan-Do-Check-Act) de la norma ISO 27001:

Acción	Prioridad	Plazo
Implementar autenticación SSH mediante clave pública	Alta	Corto plazo
Deshabilitar o restringir servicio FTP	Alta	Corto plazo
Implementar política de contraseñas robustas	Alta	Corto plazo
Configurar monitoreo continuo de logs	Media	Medio plazo
Realizar auditorías de configuración periódicas	Media	Medio plazo
Aplicar hardening completo del servidor Debian	Alta	Medio plazo

10. Recomendaciones Estratégicas

- Implementar políticas de seguridad basadas en ISO 27001
- Mantener inventario de activos
- Clasificar información crítica
- Capacitar usuarios y administradores
- Implementar monitoreo SIEM
- Aplicar controles de acceso mínimos

11. Conclusión

El análisis realizado permitió identificar vulnerabilidades importantes relacionadas con configuraciones inseguras y exposición innecesaria de servicios. Las acciones correctivas aplicadas redujeron significativamente los riesgos identificados y mejoraron la postura de seguridad del servidor Debian analizado.

El SGSI desarrollado en este documento proporciona un marco básico de gestión de seguridad alineado con ISO 27001, demostrando que las correcciones aplicadas durante el proyecto corresponden a controles reconocidos internacionalmente.

La implementación de las acciones de mejora continua definidas permitirá fortalecer progresivamente la seguridad del entorno y reducir los riesgos residuales identificados.